A PRACTICAL MONTH-BY-MONTH ACTION PLAN

THE 30-DAY *GDPR* CHALLENGE

Improve your business privacy compliance, one daily task at a time



DAILY **30** Tasks

1	2	3	4	5	6	7	8	9	10	11	12	13	14	15
16	17	18	19	20	21	22	23	24	25	26	27	28	29	30

DAILY TASKS · **DATA** MAPPING · **PRIVACY** DOCUMENTATION · **PROGRESS** TRACKING

EXERCISES · TEMPLATES · EVIDENCE FOLDER

ZIRLANDIA MILKOVIC



THE 30-DAY *GDPR* CHALLENGE

A Practical Month-by-Month Action Plan to Improve Your Business Privacy Compliance

ZIRLANDIA MILKOVIC

DAILY TASKS · DATA MAPPING · DOCUMENTATION · TRACKING

The 30-Day GDPR Challenge

A Practical Month-by-Month Action Plan to Improve Your Business Privacy Compliance

© 2026 Zirlandia Milkovic. All rights reserved. No part of this book may be reproduced, stored or transmitted in any form without written permission, except for brief quotations in reviews and for printing the worksheets, checklists and the policy template for your own business use.

NOT LEGAL ADVICE. This book is an educational guide to the EU General Data Protection Regulation (Regulation (EU) 2016/679). It is not legal advice, does not create a lawyer-client or consultant-client relationship, and does not take your individual circumstances into account. Reading it, following it or using its templates does not make a business GDPR compliant and is not a certification or a guarantee of compliance.

LAWS CHANGE. Data protection law, regulatory guidance, court decisions and national rules develop continuously. The book reflects the author's understanding as of its publication date (2026) and refers to official sources so that you can check what applies now. National laws, supervisory-authority guidance and sector rules differ between countries. Before you rely on anything here for a decision with real consequences, take advice from a qualified lawyer or data protection professional in the relevant country.

Product and company names (for example email, analytics, advertising and AI platforms) are the property of their respective owners and are used only as examples for identification and education. This independent book is not affiliated with, sponsored by or endorsed by any of them, and no product is recommended or certified as compliant.

Every person, business and incident described in the case studies and scenarios is fictional and was created to illustrate ideas. Any resemblance to real people or companies is coincidental.

Premium Edition 2026 · PDF with clickable contents, bookmarks and fillable worksheets

Contents

Note	A Note from the Author	5
01	Before Day 1	6
02	Week 1: Foundations	11
03	Week 2: Data Mapping	20
04	Week 3: Documentation	29
05	Week 4: People and Protection	38
06	Week 5: The Finish Line	48
Bonus	Challenge Toolkit	53
A–Z	Plain-English Glossary	63
Ref	Official Sources & Further Reading	64
Bio	About the Author	65

A Note from the Author

Why a challenge works better than a project plan.

Most small businesses do not fail at GDPR because they refuse to comply. They fail because compliance feels like one enormous job, and enormous jobs get postponed. The privacy policy waits for next week. The data map waits for a quiet month. The quiet month never arrives.

This book breaks the job into **thirty small days**. Each day has one task, a reason it matters, a time estimate and a clear output you can save as evidence. None of the tasks is difficult on its own. Together, they take a business from "we think we are probably fine" to a working, documented privacy programme.

You do not need a legal degree, a big budget or a compliance team. You need a calendar, 30 to 60 minutes a day, and the willingness to write things down. The GDPR is built on a simple idea: **know what you do with people's data, have a good reason for it, protect it, and be able to show that you did.** Thirty days is enough to build the habits and the paperwork for all four.

AI & PRIVACY **How to use this book**

Start with the short "Before Day 1" chapter to set up your folder and take your starting score. Then work through one day at a time. Tick each day in the tracker at the back, save the output in your evidence folder, and use the weekly review days to catch up. If you miss a day, do not restart: simply continue. The templates, registers and scorecard in the Bonus section can be filled in on screen or printed. The periods and examples given are **starting points, not legal rules**, so always check what applies in your country and sector.

SETUP · ONE HOUR

CHAPTER

01

Before Day 1

Set up your challenge, your evidence folder and your starting score in one sitting.

IN THIS CHAPTER

- How the 30 days are organised, and what you need before you start
- How to set up the evidence folder that proves your work
- Your starting Compliance Score, so you can measure progress
- The ground rules that keep the challenge realistic

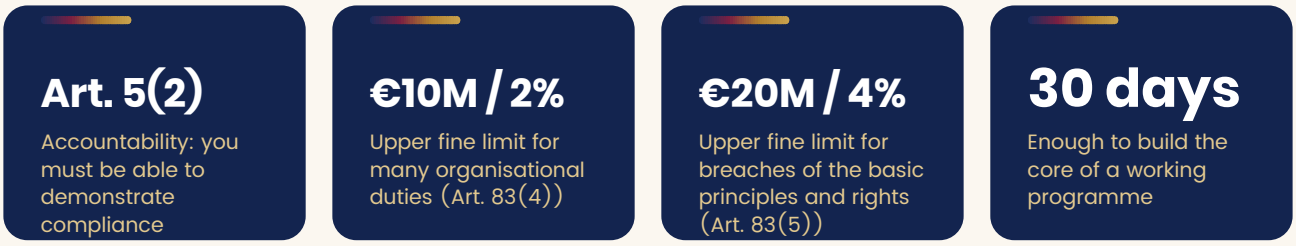
Picture a small online business with six people, a shop, a newsletter, a handful of software tools and a shared drive nobody has tidied since the company began. Nobody has ever been unkind to a customer's data. But if a customer asked, "What do you hold about me, and why?", the honest answer would be a long silence.

That silence is what the next thirty days will replace with a clear, documented answer. This chapter prepares the ground so that Day 1 can start without friction.

What the challenge is, and is not

The 30-Day GDPR Challenge is a **practical action plan** that takes you through the core of GDPR compliance in a logical order: foundations first, then data mapping, then documentation, then people and security, then a finish line. It is built for small and medium businesses, freelancers, online shops and agencies working under the EU General Data Protection Regulation (Regulation (EU) 2016/679).

It is **not** a certificate, an audit or legal advice. At the end you will not be "certified compliant", because no such certificate exists for the GDPR as a whole. You will have something more useful: a living set of records and routines that show a regulator, a client or a customer that you took data protection seriously and can prove it.



What the stakes look like

Those fine limits are maximums, and regulators look at size, intent, cooperation and harm. What they consistently ask for first is paperwork: *show me your records, your notice, your contracts, your breach log.* The challenge is designed to put that paperwork in your hands.

The five weeks at a glance



Figure 1 The journey in five steps

Every week ends with a **review day** that gathers loose ends and scores your progress. Week 5 is short on purpose: it is about locking in what you built and planning how to keep it alive.

Set up your evidence folder (15 minutes)

Create one folder called **GDPR Evidence** in a shared drive that access can be controlled on. Inside it, make seven subfolders. Every day's output goes into one of them. This folder is your proof of accountability.

Your evidence folder

Folder	What goes in it	Filled during
01 Governance	Owner, scope, policies, training records	Weeks 1, 3 and 4
02 Data Map	System register, data flows, vendor list, transfers, ROPA	Week 2
03 Notices & Consent	Privacy notice, cookie setup, marketing consent records	Week 3
04 Contracts	Data processing agreements and vendor security checks	Week 3
05 Rights Requests	Request log, templates and responses	Week 4
06 Security & Breaches	Security checklist, breach log, drill results	Week 4
07 Reviews	Weekly review notes, scorecards, the 90-day plan	Weeks 1 to 5

FOUNDER TIP **FOUNDER TIP: keep dates visible**

Put the date in every file name, for example *2026-11-03 System register v1*. Regulators like to see when something was created and when it was last reviewed, and a date in the name saves you from guessing later.

The ground rules

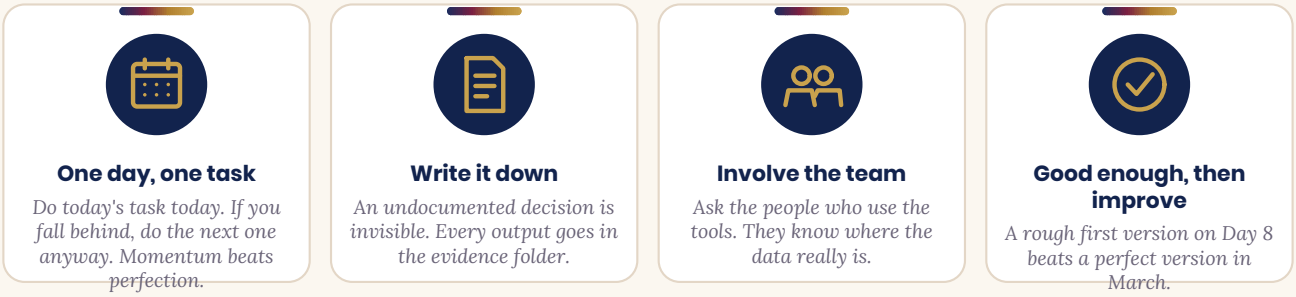


Figure 2 Four rules that keep you going

Take your starting score

Before Day 1, answer the ten questions below honestly. They are a snapshot, not a test. Give yourself **2 points** for "yes, and I can show it", **1 point** for "partly" and **0** for "no" or "not sure". You will retake the same check on Day 29, and the difference is your progress.

STARTING COMPLIANCE SCORE: 10 QUESTIONS

- ☐ Someone is named as responsible for data protection in my business.
- ☐ I can list the systems and tools that hold personal data.
- ☐ I know the lawful basis for each main use of personal data.
- ☐ My website has a privacy notice that matches what I really do.
- ☐ Cookies and trackers only run after a valid choice from the visitor.
- ☐ Every supplier that handles personal data has a signed data processing agreement.
- ☐ I know how long I keep each type of data and why.
- ☐ I have a written process for access, deletion and other requests.
- ☐ I have a written breach plan and know the 72-hour rule.
- ☐ My team has had basic privacy and security training.

0 to 6	7 to 13	14 to 20
Early stage	**Developing**	**Established**
Many gaps, which is normal. Follow the plan in order and do not skip Week 1.	Some good habits exist, but they are not written down or consistent.	You have the building blocks. Use the challenge to find the gaps and gather the evidence.

Figure 3 Score bands (maximum 20 points)

WORKSHEET

Your starting point

Write your score and your honest first impressions. You will compare this with your Day 29 result.

Starting score out of 20

The three gaps that worry me most

Who will do the challenge with me (names and roles)

Start date and planned finish date

WATCH OUT **WATCH OUT: not legal advice**

This book gives general educational guidance. Rules differ between countries and sectors, and your situation may need advice from a qualified lawyer or data protection professional. Treat every period, example and template here as a starting point to adapt.

WEEK 1 · DAYS 1 TO 7

CHAPTER

02

Week 1: Foundations

Days 1 to 7. Decide who is responsible, learn the rules of the game and understand what you are doing with data.

IN THIS CHAPTER

- Who owns data protection in your business, and whether you need a DPO
- The seven principles that every other rule grows from
- Whether you are a controller, a processor, or both
- A first inventory of data and a lawful basis for each use

Week 1 is about orientation. You will not build anything elaborate yet. You will decide who is in charge, learn the seven principles that the whole regulation rests on, work out your role, take a first look at what data you hold, and match each use of data to a legal reason. Get this week right and every later task becomes easier.

Day 1: Name your privacy owner and set your scope

The first mistake in most small businesses is that data protection belongs to everyone, and therefore to nobody. Today you fix that. Choose **one person** who is accountable for privacy day to day, and a deputy for when they are away. In a five-person company that is usually the founder or the office manager. They do not need to be a lawyer; they need to care, have time and be able to ask questions of the whole team.

Next, decide the **scope** of your challenge. Which parts of the business will you cover? Everything is the right answer for most small firms: shop, marketing, staff, suppliers and clients. Write it down so there is no argument later.

Do you need a Data Protection Officer?

A Data Protection Officer (DPO) is a formal role under Articles 37 to 39. It is mandatory only in three situations: you are a public authority, your core activities involve **large-scale regular and systematic monitoring** of people, or your core activities involve **large-scale processing of special-category or criminal-offence data**. A small shop sending a newsletter is normally not in any of these. If you are unsure, write down your reasoning. That note is itself evidence.

DAY 01

Appoint your privacy owner and define scope ☐

TODAY'S TASK Name one accountable person and a deputy, and write the scope of the challenge.

WHY IT MATTERS Accountability (Art. 5(2)) needs a named owner. Without one, nothing gets decided and nothing gets finished.

TIME NEEDED 30 minutes

CHECK Do we have a note explaining why we do or do not need a DPO?

OUTPUT One-page "Privacy Owner and Scope" note saved in 01 Governance.

WORKSHEET

Day 1 worksheet

Fill this in now and save it. It becomes the first page of your evidence folder.

Privacy owner (name and role)

Deputy (name and role)

Scope: which parts of the business are covered

DPO needed? Yes or no, and why

Day 2: Learn the seven principles

Every rule in the GDPR is an application of seven principles in **Article 5**. If you remember nothing else from the regulation, remember these. They also give you a quick test for any new idea: *does this respect all seven?*



Figure 4 The seven principles in plain English

The seventh principle, **accountability**, is the one that makes this book necessary. It is not enough to do the right thing; you must be able to **prove** it. That is why every day ends with an output you save.

GDPR IN PLAIN ENGLISH **GDPR IN PLAIN ENGLISH: personal data**

Personal data is any information relating to an identified or identifiable person (Art. 4(1)). That includes names, emails, phone numbers, addresses, IP addresses, online identifiers, photos and order histories. If you can single out a person from it, directly or by combining it with other data, treat it as personal data.

DAY 02

Test your business against the seven principles

TODAY'S TASK Write one sentence per principle describing how your business meets it today, or where it does not.

WHY IT MATTERS A short honest review reveals your weak principle early, so you can give it extra attention in later weeks.

TIME NEEDED 30 minutes

CHECK Which principle feels weakest in my business right now?

OUTPUT A one-page "Principles check" saved in 01 Governance.

Day 3: Controller, processor or both?

Your obligations depend on your **role**. A **controller** decides why and how personal data is processed. A **processor** processes data on behalf of a controller and follows their instructions (Art. 4(7) and 4(8)). Most businesses are controllers for their own customers and staff. Many are also processors, for example agencies, bookkeepers, IT providers and software companies that handle data for clients.

Controller or processor?

Situation	Likely role	Why it matters
Your shop processes customer orders	Controller	You decide the purpose and means; you owe customers a privacy notice
You run a payroll service for client companies	Processor	You need a written contract (Art. 28) and may act only on instructions
A marketing agency manages a client's email list	Processor for the client	The client sets the purpose; the agency follows instructions
Your accountant keeps your invoices	Often a processor	You need a data processing agreement with them
An agency also runs its own newsletter	Controller for its own list	The same company can be both, for different data

WATCH OUT **WATCH OUT: using a client's data for yourself**

If you are a processor, you must not start using your client's data for your own purposes, such as building a general marketing list. Doing so can turn you into a controller for that use, with all the duties (and liability) that follow (Art. 28(10)).

DAY 03

Decide your role for each main activity

TODAY'S TASK List your main activities and mark each one as controller, processor, or both.

WHY IT MATTERS Controllers write privacy notices; processors need contracts. You cannot do either correctly until you know which you are.

TIME NEEDED 30 minutes

CHECK Are there activities where we assumed we were "just a supplier" but make our own decisions about the data?

OUTPUT A role table saved in 01 Governance.

Day 4: Take a quick inventory of the data you hold

Today is a rough first sweep, not the full data map (that is Week 2). The goal is simply to see the **shape** of what you hold. Walk through the business and list every group of people whose data you have, and the main types of data for each.

CUSTOMERS AND PROSPECTS
Names, emails, addresses, orders, payment references, support emails, marketing preferences, website behaviour.

STAFF AND APPLICANTS
CVs, contracts, payroll and bank details, absence and health notes, performance records, photos, access logs.

SUPPLIERS AND CLIENTS
Contact names and roles, invoices, contracts, project files that include personal data, meeting notes.

Figure 5 Typical groups of people in a small business

Include paper, phones, shared drives, personal email accounts, chat tools and spreadsheets "just for me". These forgotten corners hold the data that causes the trouble.

QUICK INVENTORY

Group of people	Types of data	Where it lives	Rough amount
e.g. Newsletter subscribers	*Name, email, signup date*	*Email platform*	*About 3,200 people*

Group of people	Types of data	Where it lives	Rough amount

DAY
04

Complete a first inventory of people and data

TODAY'S TASK Fill the quick-inventory grid with every group of people and the main data you hold about each.

WHY IT MATTERS You cannot protect, justify or delete what you cannot name. This list drives the data map in Week 2.

TIME NEEDED 45 minutes

CHECK Did anyone on the team mention a tool or folder I had forgotten?

OUTPUT Quick inventory saved in 02 Data Map.

Day 5: Choose a lawful basis for every use

The GDPR forbids processing personal data unless you have one of **six lawful bases** in **Article 6(1)**. You need at least one for each purpose, and you must be able to say which. The common mistake is to assume consent covers everything. It does not, and it is often the *weakest* basis because it can be withdrawn at any time.

The six lawful bases

Basis	Use it when	Typical example
Consent	The person freely and clearly agrees to a specific use	Newsletter signup, non-essential cookies
Contract	Processing is needed to deliver what the person asked for	Shipping an order, running a subscription
Legal obligation	A law requires you to process the data	Keeping invoices for tax, payroll reporting
Vital interests	Needed to protect someone's life	Rare in small business
Public task	A public authority or official task	Mostly public bodies
Legitimate interests	You have a genuine interest that does not override the person's rights	Fraud prevention, B2B direct marketing in some cases, internal analytics



Figure 6 How to pick the right basis

FOUNDER TIP **FOUNDER TIP: one purpose, one basis**

Pick the basis per purpose, not per tool. "Order fulfilment" (contract), "tax records" (legal obligation) and "newsletter" (consent) can all sit in the same shop system. Write each pair down in a table.

DAY 05

Match each purpose to a lawful basis

TODAY'S TASK List your main purposes and write the lawful basis next to each one.

WHY IT MATTERS A privacy notice must state the basis for each purpose (Arts. 13 and 14), so you need these answers before Week 3.

TIME NEEDED 45 minutes

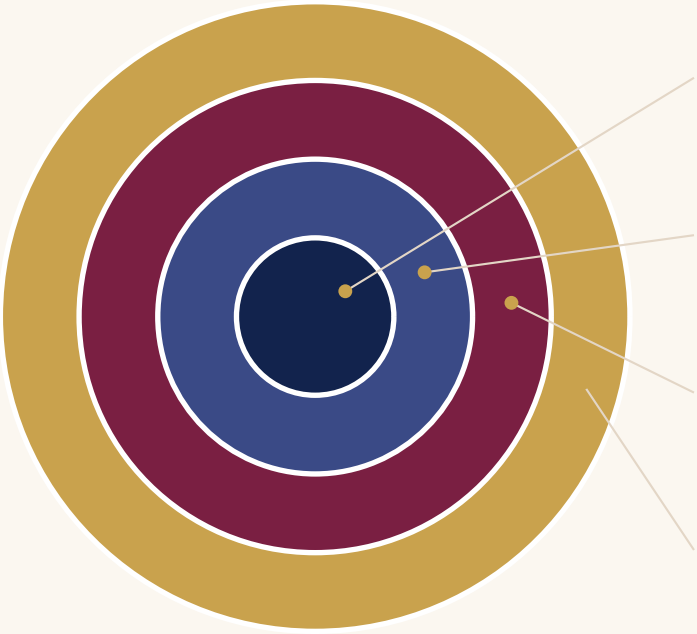
CHECK Are we relying on consent anywhere that contract or legal obligation would be stronger?

OUTPUT A purposes-and-bases table saved in 01 Governance.

Day 6: Spot the high-risk categories

Some data deserves extra care because misuse can hurt people badly. **Article 9** protects the **special categories**: racial or ethnic origin, political opinions, religious or philosophical beliefs, trade-union membership, genetic and biometric data used to identify someone, health data, and data about sex life or sexual orientation. Processing them is prohibited unless one of the narrow exceptions in Article 9(2) applies, and you also need an Article 6 basis. Criminal-conviction data has its own rule in Article 10.

Watch for these in everyday life: sickness notes in HR, dietary requests that reveal religion or health, fingerprint or face-recognition door entry, photos of people at events, and any form with a free-text box where people type sensitive things.



1 Children

Services aimed at children need extra care. Age of digital consent under Art. 8 is 16, but member states may lower it to as low as 13.

2 Employees

Staff cannot freely say no to their employer, so consent is rarely a valid basis in employment.

3 Special-category data

Health, beliefs, biometrics and similar data. Needs an Article 9 exception.

4 Everyone else

Ordinary personal data still needs a basis, security and a limited lifespan.

Figure 7 Who deserves the most protection

DAY
06

Find special-category, children's and high-risk data

☐

TODAY'S TASK Check your inventory for special-category data, children's data, large-scale monitoring or anything else that could seriously affect people.

WHY IT MATTERS These categories trigger stricter rules and may require a DPIA (Day 20). Finding them now avoids surprises later.

TIME NEEDED 30 minutes

CHECK Could we stop collecting any of this, or collect it in a less sensitive form?

OUTPUT A short "High-risk data" list saved in 02 Data Map.

Day 7: Week 1 review and progress check

Today is deliberately light. Re-read your outputs from Days 1 to 6, fix gaps and make sure everything is saved with a date in the file name. Then rate yourself below. If something is missing, finish it before you start Week 2; the data map depends on a clear owner, a clear role and a clear inventory.

WEEK 1 COMPLETION CHECK

- ☐ A named privacy owner and deputy are written down.
- ☐ The scope of the challenge is defined.
- ☐ I have checked each of the seven principles against the business.
- ☐ I know whether we act as controller, processor or both.
- ☐ A first inventory of people and data exists.

- [ ] Each main purpose has a lawful basis.
- [ ] Special-category and children's data have been identified.

DAY
07

Review Week 1 and tidy your evidence

TODAY'S TASK Complete any missing outputs from Days 1 to 6 and save everything to the evidence folder.

WHY IT MATTERS Reviews turn rushed notes into reliable records, and stop small gaps growing into large ones.

TIME NEEDED 30 minutes

CHECK What was the hardest day this week, and what does that tell me?

OUTPUT A dated Week 1 review note saved in 07 Reviews.

WEEK 2 · DAYS 8 TO 14

CHAPTER

03

Week 2: Data Mapping

Days 8 to 14. Find every system, follow the data, list your vendors and build your record of processing.

IN THIS CHAPTER

- A register of every system that holds personal data
- How data flows in, through and out of your business
- A vendor list with the right contracts and locations
- Rules for sending data outside the EU and EEA
- A first Record of Processing Activities (ROPA)

Data mapping is the heart of the challenge. It is the point where vague worry becomes a concrete list. A good map answers four questions for every piece of data: **where did it come from, where does it live, who can see it, and where does it go next?** It is also the most useful thing you will build, because the privacy notice, the contracts, the retention rules and the breach plan all draw on it.



Day 8: Build your system register

List every system, app, device and folder that holds personal data. Start with the obvious: your website and shop, payment provider, email platform, CRM, accounting software, HR and payroll tools, helpdesk, cloud drive, messaging apps and analytics. Then add the less obvious: spreadsheets on laptops, WhatsApp groups with customers, personal phones used for work, paper files, USB sticks, forms and survey tools, scheduling apps, webinar tools and old systems you stopped using but never closed.

WATCH OUT **WATCH OUT: shadow IT**

Team members often adopt free tools to get work done, with customer data inside. Ask every person on the team, "What do you use that nobody officially approved?" Do not make it a blame exercise. You want honest answers, and you will only get them if people are not afraid.

SYSTEM REGISTER

System or tool	What it is used for	Personal data inside	Who has access	Owner
e.g. Shopify	*Online shop*	*Customer names, addresses, orders*	*Founder, support*	*Founder*

System or tool	What it is used for	Personal data inside	Who has access	Owner

DAY
08

Create the system register

TODAY'S TASK List every tool, device and folder that holds personal data, with its purpose and owner.

WHY IT MATTERS You cannot protect, update or delete a system you do not know exists. Every later task builds on this list.

TIME NEEDED 60 minutes

CHECK How many systems did we find that nobody could explain?

OUTPUT System register saved in 02 Data Map.

Day 9: Trace the data flows

A data flow is the journey data takes. Pick your three most important journeys, such as **a customer order**, **a newsletter signup** and **hiring an employee**, and trace each from the first click to the last place it lands. Draw the path on paper as boxes and arrows. Mark every point where a third party receives the data.



Figure 8 Example: a customer order

Each arrow is a handover, and each handover raises questions: is it necessary, is it secure, is there a contract, and where is the receiver located? Flows are also where you discover data you do not need. If the courier only needs a name and address, why do they also receive the phone number and order notes?

FOUNDER TIP **FOUNDER TIP: ask "why does this arrow exist?"**

For every arrow on your diagram, finish the sentence "*We send this data to them because...*". If you cannot, you may be sharing more than you should, which breaches data minimisation.

DAY
09

Map three key data flows

☐

TODAY'S TASK Draw the flow for an order, a signup and a hire, and mark every external recipient.

WHY IT MATTERS Flows show where data leaves your control, which is where most breaches and transfer problems begin.

TIME NEEDED 45 minutes

CHECK Which flow had the most recipients, and are they all necessary?

OUTPUT Three flow diagrams saved in 02 Data Map.

Day 10: List your vendors and processors

Every supplier that touches personal data on your behalf is a **processor** (or sometimes a joint controller), and each needs a proper contract. Build a vendor list from your system register and flows: hosting, email, payments, analytics, accounting, payroll, helpdesk, cloud storage, IT support, designers and freelancers who see customer files.

VENDOR REGISTER

Vendor	What they do for us	Data they receive	Location of data	DPA signed?
e.g. Email platform	*Sends newsletters*	*Names and emails*	EU / USA	Yes, 2026-03-12

For each vendor note where the data is stored, whether sub-processors are used, and whether you have a signed **data processing agreement (DPA)**. Most large vendors publish a standard DPA you can accept online; save a copy, because the page can change.

DAY
10

Build the vendor register

☐

TODAY'S TASK List every vendor that handles personal data, with the data received, location and DPA status.

WHY IT MATTERS Article 28 requires a written contract with every processor. Missing DPAs are one of the easiest things for a regulator to spot.

TIME NEEDED 60 minutes

CHECK Which vendors have no DPA yet? I will fix these in Week 3.

OUTPUT Vendor register saved in 02 Data Map.

Day 11: International transfers

The GDPR protects data even when it leaves Europe. Chapter V (Articles 44 to 49) says personal data may be sent outside the EU and EEA only if the receiving country or organisation offers an adequate level of protection, or you add a safeguard. Cloud tools make transfers easy to do without noticing: a US email platform, an analytics tool, a support chat provider.

The main transfer routes

Route	What it means	What to check
Adequacy decision	The European Commission has decided a country offers adequate protection	The country or framework is on the Commission's current list
EU-US Data Privacy Framework	An adequacy decision (July 2023) covering US companies that self-certify	The vendor is currently listed as certified, and the data type is covered
Standard Contractual Clauses (SCCs)	Approved contract terms between exporter and importer	Signed SCCs plus a transfer risk assessment
Other safeguards or derogations	Binding corporate rules, explicit consent for one-off cases, and others	Use only for specific cases and with advice

1	**Is the receiving country (or framework) covered by a current EU adequacy decision?**	**YES** Yes, document the decision and continue	**NO** Continue to question 2
2	**Does the vendor sign Standard Contractual Clauses with a transfer risk assessment?**	**YES** Yes, save the signed clauses and the assessment	**NO** Continue to question 3
3	**Can the same result be achieved with an EU-based provider or EU hosting?**	**YES** Switch to the EU option	**NO** Pause the transfer and take advice

Figure 9 Can I send this data outside the EEA?

AI & PRIVACY **AI & PRIVACY: check, don't assume**

Transfer rules and frameworks have been challenged in court before and may be again. Treat any adequacy framework as something to **re-check at each annual review**, and keep a dated screenshot or copy of the vendor's certification or contract as evidence.

DAY **11**

Check every non-EEA transfer

TODAY'S TASK Mark each vendor in your register that sends or stores data outside the EU and EEA, and record the transfer route.

WHY IT MATTERS Unlawful transfers are among the most heavily enforced areas of the GDPR, and the paperwork is usually easy to fix.

TIME NEEDED 45 minutes

CHECK Which vendors need new clauses or a switch to EU hosting?

OUTPUT A "Transfers" column added to the vendor register.

Day 12: Connect data to retention and deletion

For each system on your register, decide **how long** the data stays and **what happens** at the end. This is the storage-limitation principle in practice. Do not aim for perfection; a short, specific rule beats a perfect rule that never gets written. Start with the data most likely to pile up: marketing lists, support emails, old customer accounts, applicant CVs and backups.

Starting points (check your local rules)

Data	Example period	Trigger
Order and invoice records	Often 5 to 10 years	End of the financial year (tax and accounting law)
Active customer account	While the relationship lasts	Last purchase or contract end
Inactive marketing contacts	Often 24 to 36 months	Last interaction
Support emails	1 to 2 years	Case closed
Rejected job applicants	Commonly 6 to 12 months	Decision date
Website security logs	Weeks to a few months	Rolling deletion

GDPR IN PLAIN ENGLISH **GDPR IN PLAIN ENGLISH: no magic number**

The GDPR does not set a standard retention period. It requires you to keep data no longer than necessary (Art. 5(1)(e)). Some laws set minimums, such as tax and payroll rules, which differ by country. Write down the period, the trigger and the reason.

DAY 12

Add retention rules to your map ☐

TODAY'S TASK Next to each system or data group, record how long you keep it, what starts the clock and what happens at the end.

WHY IT MATTERS The privacy notice (Art. 13(2)(a)) must tell people how long you keep their data. You cannot say it until you have decided it.

TIME NEEDED 45 minutes

CHECK Where are we keeping data "just in case" with no clear purpose?

OUTPUT Retention column added to the system register.

Day 13: Draft your Record of Processing Activities

Article 30 requires a written Record of Processing Activities (ROPA). There is an exemption for organisations with fewer than 250 employees, but it applies only if the processing is occasional, low risk and involves no special-category data. In practice almost every business regularly processes staff and customer data, so the safe assumption is: **you need one.** Even if you did not, it is the best single document for showing accountability.

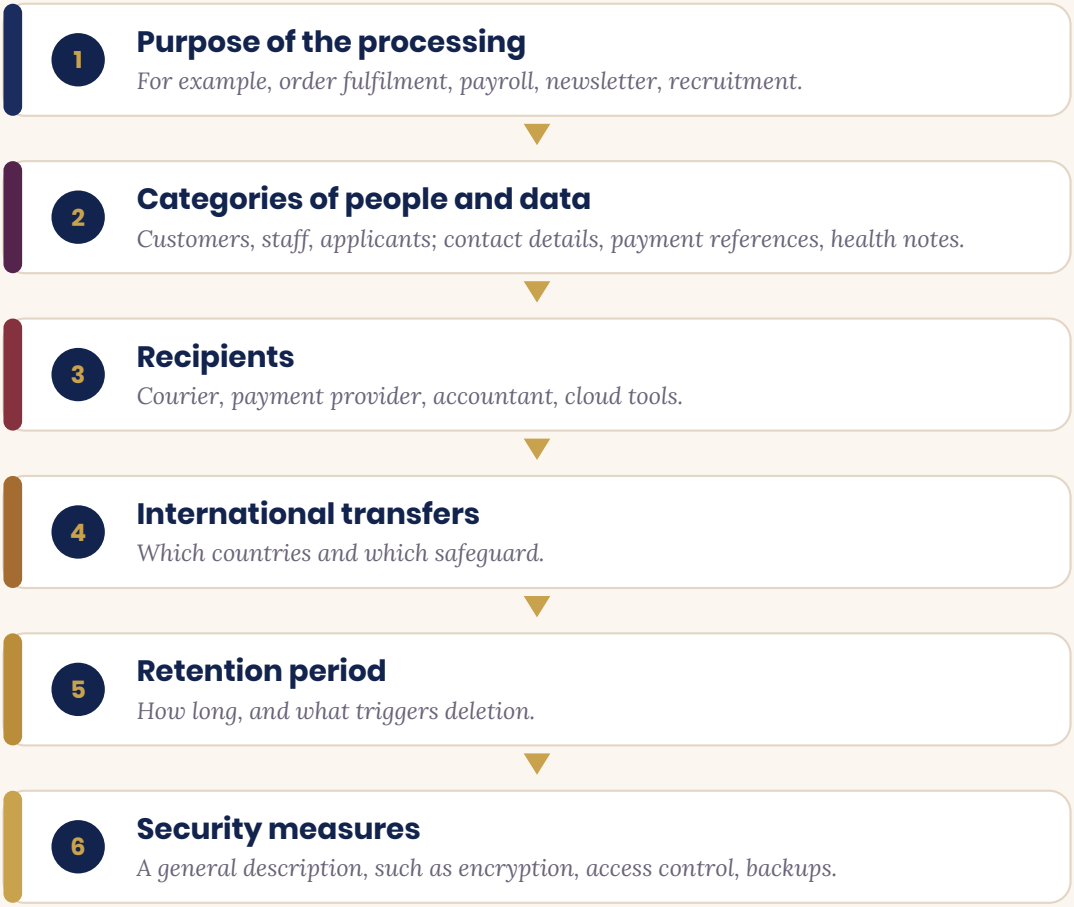


Figure 10 What a ROPA entry contains

You already have most of this from Days 4 to 12. Today you simply reorganise it, one row per purpose. Use the ROPA grid in the Bonus section, or a spreadsheet of your own with the same columns.

DAY
13

Draft your first ROPA

TODAY'S TASK Write one ROPA row for each processing purpose, using your register, flows and retention rules.

WHY IT MATTERS A ROPA is the master record regulators ask for first. It also exposes missing information that you can chase in Week 3.

TIME NEEDED 90 minutes (the longest day of the challenge)

CHECK Which cells are blank, and who can fill them in?

OUTPUT ROPA v1 saved in 02 Data Map.

Day 14: Week 2 review

Check that the five outputs agree with each other. Every system on the register should appear in at least one flow. Every vendor should appear on the register. Every purpose in the ROPA should have a lawful basis from Day 5. Where something is missing, add it. Then ask one more person to read your map and tell you what they would have added.

WEEK 2 COMPLETION CHECK

- [ ] Every system and device with personal data is on the register.
- [ ] Three key data flows are drawn and every recipient is identified.
- [ ] The vendor register shows data, location and DPA status.
- [ ] Every transfer outside the EEA has a recorded route.
- [ ] Retention rules exist for the main data groups.
- [ ] A ROPA draft covers all processing purposes.
- [ ] Someone other than me has read and challenged the map.

DAY 14

Review Week 2 and cross-check the map

TODAY'S TASK Make sure systems, flows, vendors, retention and ROPA agree with each other and fill any gaps.

WHY IT MATTERS A map with contradictions is worse than none, because it gives false comfort.

TIME NEEDED 45 minutes

CHECK What did the reviewer add that I missed?

OUTPUT Updated map and a dated Week 2 review note in 07 Reviews.

WEEK 3 · DAYS 15 TO 21

CHAPTER

04

Week 3: Documentation

Days 15 to 21. Turn what you know into notices, consent, contracts, policies and risk assessments.

IN THIS CHAPTER

- A privacy notice that says what you really do
- Cookie and marketing consent that stands up to scrutiny
- Data processing agreements with every vendor
- Five short policies that people will actually read
- When you need a DPIA and how to record a legitimate-interests test

Now that you know what you do with data, you can write it down. Week 3 is paperwork week, but it is paperwork with a purpose: every document here either **informs people**, **binds a supplier** or **guides your team**. Keep them short, specific and true. A privacy notice that describes what you wish you did is worse than none.

Day 15: Write a privacy notice that matches reality

Articles 13 and 14 require you to give people clear information when you collect their data: who you are, why you use it, on what basis, who receives it, how long you keep it, and what rights they have. The notice must be concise, transparent, intelligible and easy to find, written in plain language (Art. 12).

WHAT A PRIVACY NOTICE MUST COVER

- [ ] Who you are and how to contact you (and your DPO, if you have one).
- [ ] Each purpose of processing, with its lawful basis.
- [ ] The legitimate interests relied on, where that basis is used.
- [ ] Who receives the data (categories of recipients and processors).
- [ ] Transfers outside the EEA and the safeguard used.
- [ ] How long you keep the data, or the criteria for deciding.
- [ ] The person's rights: access, correction, erasure, restriction, objection, portability.
- [ ] The right to withdraw consent at any time, where consent is the basis.
- [ ] The right to complain to a supervisory authority.
- [ ] Whether providing the data is required, and what happens if they refuse.
- [ ] Any automated decision-making or profiling that has legal or similarly significant effects.

BEFORE & AFTER **A retention statement in a privacy notice**

RISKY	*We keep your data for as long as necessary for business purposes.*
BETTER	*We keep order records for 7 years because tax law requires it, and newsletter details until you unsubscribe.*
BEST PRACTICE	*Orders and invoices: 7 years (tax law). Newsletter: until you unsubscribe, then your email stays on a suppression list so we do not message you again. Support emails: 2 years after the case closes.*
WHY IT MATTERS	Specific periods show that you have decided. Vague wording signals that you have not.

FOUNDER TIP **FOUNDER TIP: layer your notice**

Put a short summary at the top ("who we are, what we do with your data, your main rights") and the full detail below it. Link the notice at every point where you collect data: checkout, signup forms, contact forms and your site footer.

DAY 15

Draft or rewrite your privacy notice

TODAY'S TASK Write a notice from your ROPA and check it against the checklist above.

WHY IT MATTERS People cannot exercise rights over processing they do not know about. A mismatched notice is also a transparency breach.

TIME NEEDED 90 minutes

CHECK Does anything in the notice describe a practice we do not actually follow?

OUTPUT Privacy notice v1 saved in 03 Notices & Consent.

Day 16: Fix cookies and online tracking

Two laws apply to cookies. The **ePrivacy rules** (implemented nationally from Directive 2002/58/EC, Article 5(3)) require consent before storing or reading information on a device, unless it is strictly necessary for a service the user asked for. The **GDPR** then governs the personal data those cookies collect, and sets the standard for valid consent (Arts. 4(11) and 7).

What counts as valid cookie consent

Requirement	In practice
Prior	Non-essential cookies and trackers do not load until the visitor agrees
Informed	Plain explanation of each purpose and who receives the data
Specific	Choices by purpose (for example analytics and advertising), not one bundled yes
Freely given	No cookie wall that blocks the site, and no pre-ticked boxes
As easy to withdraw	A way to change or withdraw consent later that is as easy as giving it
Provable	You can show who agreed, when and to what

The Court of Justice confirmed in the *Planet49* ruling (Case C-673/17, 2019) that pre-ticked boxes do not give valid consent. Many authorities also expect "reject all" to be as easy to find as "accept all".

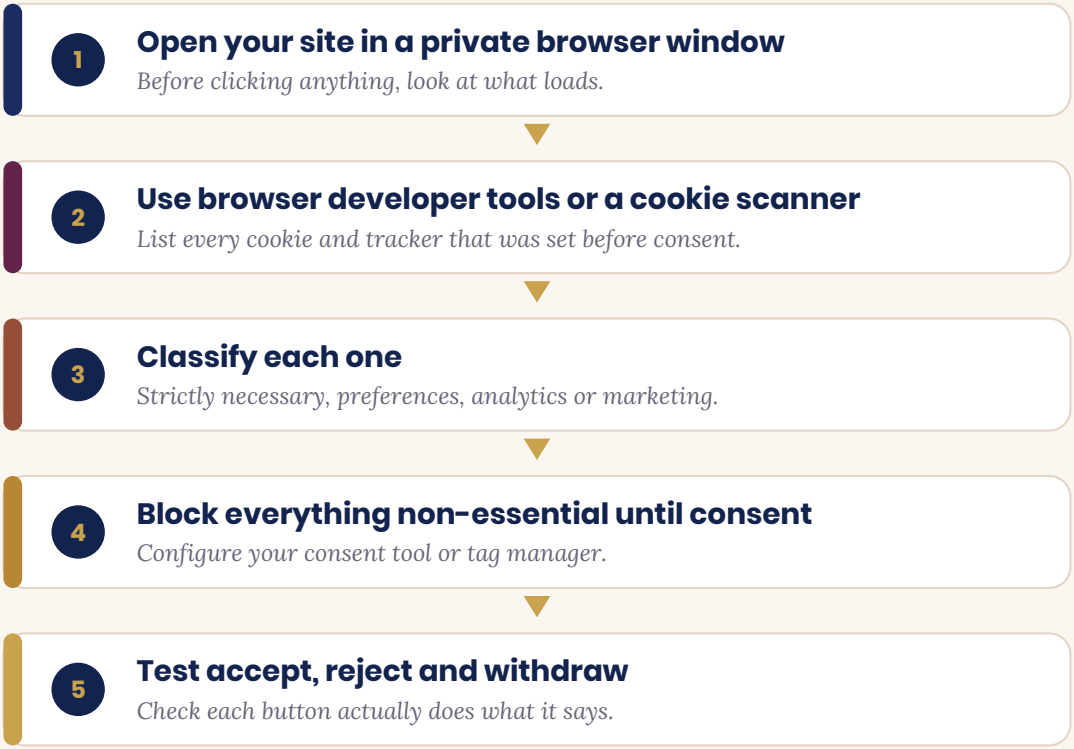


Figure 11 Your 30-minute cookie audit

DAY
16

Audit and fix cookies and trackers

TODAY'S TASK Scan your site, list every cookie, and make sure non-essential ones only load after valid consent.

WHY IT MATTERS Trackers firing before consent are visible to regulators with a few clicks, which makes this a common enforcement target.

TIME NEEDED 60 minutes

CHECK Which tracker did we install long ago and no longer really use?

OUTPUT Cookie list and consent settings screenshot saved in 03 Notices & Consent.

Day 17: Make your marketing lawful

Email and SMS marketing is governed by the ePrivacy rules (in most countries, national laws implementing Article 13 of Directive 2002/58/EC) as well as the GDPR. The usual rule for consumers is **prior consent**. A common exception, often called the "soft opt-in", allows you to email your own existing customers about similar products or services, provided you gave a clear chance to opt out when you collected the address and in every message. Rules for business-to-business email vary widely between countries.

RISKY: COLLECTING CONTACTS THE EASY WAY

- Pre-ticked newsletter box at checkout.
- Adding everyone who ever emailed you to the list.
- Buying or renting an email list.
- No record of when or how someone joined.
- Unsubscribe link that is hard to find or needs a login.

STRONGER: CONSENT YOU CAN PROVE

- An unticked box with a plain statement of what they will receive.
- A confirmed (double opt-in) signup with a date and source recorded.
- A footer link that removes the person immediately.
- A suppression list, so unsubscribed people are never re-added.
- A yearly clean-up of contacts who no longer engage.

Figure 12 Marketing consent

DAY 17

Check your marketing consent and unsubscribe flow

☐

TODAY'S TASK Review how people join your lists, what you record, and how they leave.

WHY IT MATTERS Consent must be provable (Art. 7(1)), and people must be able to withdraw as easily as they gave it (Art. 7(3)).

TIME NEEDED 45 minutes

CHECK Could I show a regulator when and how each subscriber agreed?

OUTPUT A marketing consent summary and a test of the unsubscribe link saved in 03 Notices & Consent.

Day 18: Put data processing agreements in place

Article 28 says a controller may only use processors that give sufficient guarantees, and the relationship must be governed by a **written contract**. Today you work through the gaps found on Day 10. For most mainstream vendors, you only need to find, accept and save their standard DPA.

WHAT A DATA PROCESSING AGREEMENT MUST SAY (ART. 28(3))

- ☐ The vendor processes data only on your documented instructions.
- ☐ People who handle the data are bound by confidentiality.
- ☐ Appropriate security measures are in place (Art. 32).
- ☐ Sub-processors need your authorisation and carry the same obligations.
- ☐ The vendor helps you answer rights requests.
- ☐ The vendor helps with security, breach notification and DPIAs.
- ☐ The vendor deletes or returns data when the service ends.
- ☐ You can obtain information to show compliance, and audits are allowed.

WATCH OUT **WATCH OUT: freelancers and small suppliers**

Designers, virtual assistants and bookkeepers often get access to customer data but never sign anything. They are processors too. A one-page agreement is better than nothing, and the Bonus section includes the points to cover.

DAY 18

Close the DPA gaps

TODAY'S TASK For every vendor without a signed DPA, find the vendor's standard DPA, accept or sign it, and save a dated copy.

WHY IT MATTERS A missing processor contract is a clear, documentable breach of Article 28, and is fixed in minutes with most vendors.

TIME NEEDED 60 minutes

CHECK Are there vendors whose DPA terms look weak, such as unlimited sub-processors or no deletion promise?

OUTPUT Signed DPAs saved in 04 Contracts; register updated.

Day 19: Write five short policies

You do not need a 60-page manual. You need a handful of short, clear policies that tell the team what to do. Aim for one page each, written in everyday language, with an owner and a review date.

DATA PROTECTION POLICY
Principles, roles, how people handle personal data, and who to ask. The umbrella document.

RETENTION AND DELETION POLICY
Periods, triggers and how deletion happens, built from Day 12.

RIGHTS REQUESTS PROCEDURE
How requests are received, logged, checked and answered within one month (Day 22).

BREACH RESPONSE PLAN
What counts as a breach, who to tell, and the 72-hour clock (Day 25).

ACCEPTABLE USE AND SECURITY POLICY
Passwords, devices, email, shared drives and personal phones (Days 23 and 24).

Figure 13 Your five core policies

Write the first two today and outline the other three. The outlines are finished during Week 4, when you reach those topics.

DAY
19

Write the data protection and retention policies

☐

TODAY'S TASK Draft two one-page policies and outline the other three, each with an owner and review date.

WHY IT MATTERS Policies turn a good intention into an instruction that staff can follow and you can enforce.

TIME NEEDED 90 minutes

CHECK Would a new starter understand these policies without help?

OUTPUT Two policies and three outlines saved in 01 Governance.

Day 20: Screen for DPIAs and record your legitimate-interests tests

A **Data Protection Impact Assessment (DPIA)** is required under **Article 35** when processing is likely to result in a high risk to people. Typical triggers: large-scale profiling, systematic monitoring of public areas, large-scale use of special-category data, or new technology that could seriously affect people. Regulators publish lists of processing that always needs a DPIA, so check your national list.

DPIA SCREENING: ANY "YES" MEANS LOOK CLOSER

- ☐ Do we evaluate or score people automatically, for example profiling or credit-type decisions?
- ☐ Do we monitor people systematically, such as CCTV, tracking or employee monitoring?
- ☐ Do we process special-category data or children's data on a large scale?
- ☐ Do we combine datasets in a way people would not expect?
- ☐ Are we introducing new technology, such as facial recognition or an AI tool that makes decisions about people?

If you rely on **legitimate interests** for any purpose, write a short three-part test: **purpose** (what is our interest?), **necessity** (do we really need this data to achieve it?) and **balance** (would the person reasonably expect it, and does it harm them?). A paragraph per purpose is enough.

WORKSHEET

Legitimate-interests test

Complete one for each purpose where legitimate interests is your basis.

Purpose and our interest

Why is this data necessary to achieve it?

Would the person expect it? What is the impact on them?

Decision and safeguards (opt-out, shorter retention, less data)

DAY 20

Run DPIA screening and write your balancing tests

☐

TODAY'S TASK Check every processing activity against the screening questions and write a legitimate-interests test for each purpose that relies on it.

WHY IT MATTERS A DPIA done early is cheap; one done after launch is painful. A written balancing test is your defence for legitimate interests.

TIME NEEDED 60 minutes

CHECK Do we need a full DPIA for anything, or can we reduce the risk so that we do not?

OUTPUT Screening result and balancing tests saved in 01 Governance.

Day 21: Week 3 review

Read your privacy notice next to your ROPA. Do the purposes, bases, recipients and retention periods match line for line? Do the cookie settings match the notice? Do the vendors named in the notice have DPAs? A mismatch between the documents is the commonest finding in real audits.

WEEK 3 COMPLETION CHECK

- ☐ The privacy notice matches the ROPA and the real practice.
- ☐ Cookies and trackers wait for valid consent.
- ☐ Marketing lists have a proven opt-in and a working unsubscribe.

- [ ] Every processor has a signed agreement.
- [ ] Two policies are written and three more are outlined.
- [ ] DPIA screening is done, with balancing tests recorded.

DAY
21

Review Week 3 and cross-check your documents

TODAY'S TASK Compare notice, ROPA, cookies, contracts and policies, and correct every mismatch.

WHY IT MATTERS Consistent documents are credible; contradictions suggest the paperwork was written for show.

TIME NEEDED 45 minutes

CHECK Which document was furthest from the truth, and why?

OUTPUT Corrected documents and a dated Week 3 review note in 07 Reviews.

WEEK 4 · DAYS 22 TO 28

CHAPTER

05

Week 4: People and Protection

Days 22 to 28. Handle rights requests, secure your systems, prepare for a breach and train your team.

IN THIS CHAPTER

- A procedure for access, deletion and other rights requests
- Practical security controls that fit a small business
- A breach plan that meets the 72-hour rule
- A short training session for your team
- A drill that tests whether your plan really works

Documents do not protect anyone until people use them. Week 4 is about the human side of the GDPR: the person who writes to ask what you hold about them, the employee who clicks a phishing link, the laptop left on a train. The goal is not a perfect score. It is that when something happens, your team knows exactly what to do.

Day 22: Be ready for rights requests

The GDPR gives people eight rights. Requests can arrive by email, a web form, social media, a phone call or a letter, and they do not have to mention the GDPR. You normally must respond **within one month** (Art. 12(3)), extendable by up to two further months for complex or numerous requests, and you must tell the person about the extension within the first month.

The main rights and what they mean

Right	Article	What the person can ask
Be informed	13 and 14	Clear information about how their data is used
Access	15	A copy of their data and details of the processing
Rectification	16	Correction of inaccurate or incomplete data
Erasure	17	Deletion when there is no longer a valid reason to keep it
Restriction	18	A pause on use while a dispute is resolved
Portability	20	Their data in a structured, common, machine-readable format
Object	21	Stop processing based on legitimate interests, and stop direct marketing at any time
Automated decisions	22	Human review of decisions made solely by automated means that significantly affect them



Figure 14 Handling a request, step by step

WHAT GDPR REQUIRES **WHAT GDPR REQUIRES: no fee**

Requests are normally free of charge (Art. 12(5)). You may refuse or charge a reasonable fee only when a request is manifestly unfounded or excessive, and you must be able to justify that.

RIGHTS REQUEST LOG

Date received	Who and what type	Verified?	Deadline	Reply sent	Notes
e.g. 2026-04-02	*Customer, deletion*	*Yes, known email*	2026-05-02	2026-04-09	*Invoices kept 7 years (tax)*

DAY
22

Write your rights-request procedure

TODAY'S TASK Finish the rights-requests policy, set up the request log and name who handles requests and their backup.

WHY IT MATTERS Missed deadlines are the commonest source of complaints to regulators, and they are entirely avoidable.

TIME NEEDED 60 minutes

CHECK If a request arrived at a staff member's personal inbox today, would it reach the right person?

OUTPUT Procedure and empty request log saved in 05 Rights Requests.

Day 23: Control who can access what

Article 32 requires "appropriate technical and organisational measures" to secure personal data, taking account of risk and cost. For a small business, the single most effective measure is controlling who can get in. Most breaches begin with a stolen password or an account that should have been closed.



Figure 15 The four access basics

ACCESS REVIEW

- [ ] Every system on the register has a named list of users.
- [ ] Nobody shares a login; each person has their own account.
- [ ] Multi-factor authentication is on for email, admin and finance tools.
- [ ] Former staff and old freelancers have no active accounts.
- [ ] Admin rights are limited to the people who truly need them.
- [ ] A password manager is available to the whole team.

DAY
23

Review and tighten access

TODAY'S TASK For each key system, list who has access and remove anyone who should not, then turn on multi-factor authentication.

WHY IT MATTERS Access control is the cheapest, most effective way to reduce both the chance and the size of a breach.

TIME NEEDED 60 minutes

CHECK Which accounts were still open that should have been closed months ago?

OUTPUT Access review notes saved in 06 Security & Breaches.

Day 24: Secure devices, email and backups

Next, look at the equipment your team actually uses: laptops, phones, USB sticks, home networks and email. Aim for a short baseline that everyone follows, not a long list that nobody reads.

A practical security baseline

Area	Minimum standard	Why
Devices	Disk encryption, screen lock, automatic updates	A lost laptop is not a breach if the data cannot be read
Email	Spam and phishing filters, multi-factor, caution with attachments	Phishing is the leading way into small businesses
Backups	Regular, tested and stored separately; limited retention	Protects against ransomware and accidental deletion
Sharing	Share links with named people and expiry dates, not "anyone with the link"	Prevents accidental exposure of files
Software	Updates applied promptly; unused apps removed	Fixes known weaknesses before attackers use them
Paper	Locked storage; shredding at end of life	Physical records count too

DO THIS NOW **DO THIS NOW: test one backup restore**

A backup you have never restored is a hope, not a control. Pick one file and restore it from backup today. Note how long it took and whether it worked.

DAY
24

Apply the security baseline

TODAY'S TASK Check every device and account against the baseline table and fix the gaps you can fix today.

WHY IT MATTERS Article 32 expects measures that fit the risk. A written baseline plus proof you checked it is strong evidence.

TIME NEEDED 60 minutes

CHECK What is the biggest single security gap, and what is the quickest way to close it?

OUTPUT Completed security checklist saved in 06 Security & Breaches.

Day 25: Prepare your breach plan

A **personal data breach** is a breach of security leading to the accidental or unlawful destruction, loss, alteration, unauthorised disclosure of, or access to, personal data (Art. 4(12)). It includes a lost laptop, an email sent to the wrong person, ransomware and a hacked account.

Hour 0
Discovery
Someone notices. They tell the privacy owner at once and do not try to hide or fix it alone.

Hours 1 to 24
Contain and assess
Stop the leak, secure accounts, and assess what happened, what data, how many people and how serious.

By hour 72
Notify the authority
Unless the breach is unlikely to result in a risk to people, notify your supervisory authority without undue delay and where feasible within 72 hours of becoming aware (Art. 33).

If high risk
Tell the people
Where the breach is likely to result in a high risk, tell affected individuals directly and in plain language (Art. 34).

Always
Record it
Every breach, including those you do not report, goes in your breach log with the facts, effects and action (Art. 33(5)).

Figure 16 The breach clock

BREACH LOG

Date found	What happened	Data and people affected	Risk level	Reported?	Action taken
e.g. 2026-05-10	*Email sent to the wrong customer*	*One order confirmation, 1 person*	*Low*	*No, logged only*	*Asked recipient to delete; staff reminded*

Date found	What happened	Data and people affected	Risk level	Reported?	Action taken

WATCH OUT **WATCH OUT: the clock starts when you are aware**

The 72 hours run from when you become aware of the breach, not from when you finish investigating. Staff must know that "tell the privacy owner immediately" is the rule, even on a Friday evening.

DAY 25

Write the breach response plan

TODAY'S TASK Create a one-page plan with who to tell, how to assess risk, how to contact your authority and where to record each incident.

WHY IT MATTERS When a breach hits, there is no time to invent a process. A prepared plan makes the 72-hour deadline achievable.

TIME NEEDED 60 minutes

CHECK Do we know which supervisory authority we notify and how its reporting form works?

OUTPUT Breach plan and blank breach log saved in 06 Security & Breaches.

Day 26: Train your team

Staff are your first line of defence and, often, the cause of the incident. Training does not need to be long. A **20-minute session** covering the same five points is enough to change behaviour, if you repeat it each year and for every new joiner.

WHAT AND WHY (5 MIN)

What counts as personal data, why the GDPR matters, and the real cost of an incident for a small business.

THE EVERYDAY RULES (10 MIN)

Strong passwords and MFA, spotting phishing, careful sharing, using approved tools only, locking screens and working in public places.

WHAT TO DO WHEN SOMETHING GOES WRONG (5 MIN)

How to spot a breach or a rights request, and who to tell at once. No blame for honest reports.

Figure 17 A 20-minute training outline

FOUNDER TIP **FOUNDER TIP: reward the early report**

The person who admits a mistake in the first hour saves you days. Make it safe to report. Thank them in front of the team.

TRAINING RECORD

Date	Person	Session or topic	Delivered by	Signed or confirmed	Next refresh
e.g. 2026-05-14	*A. Smith*	*GDPR basics and phishing*	*Privacy owner*	*Yes*	*2027-05*

DAY
26

Run a team training session

TODAY'S TASK Deliver the 20-minute session to everyone with access to personal data and record who attended.

WHY IT MATTERS Training records demonstrate that you take the human side seriously (Art. 32(4)) and make future incidents less likely.

TIME NEEDED 45 minutes including preparation

CHECK Which question from the team showed a gap in my own explanation?

OUTPUT Attendance record and slides or notes saved in 01 Governance.

Day 27: Test it with a drill

A plan that has never been tested usually has a hole in it. Today you run two short drills with the privacy owner and one colleague. They take about 15 minutes each and cost nothing.

REAL-WORLD SCENARIO **REAL-WORLD SCENARIO: the Friday inbox**

At 4:50 pm on Friday, a customer writes to the general support inbox: "Please send me all the data you hold about me and then delete my account." The inbox is checked by a part-timer who does not work on Fridays. The message sits until Monday. The one-month clock started on Friday. A good procedure routes unfamiliar requests to the privacy owner the same day; a good drill finds the weak link before a real customer does.

DRILL 1: RIGHTS REQUEST

- [ ] Send yourself a mock access request through your normal channel.
- [ ] Check who sees it and how fast it reaches the privacy owner.
- [ ] Log it, verify identity and find the data in at least three systems.
- [ ] Draft the reply and note how long the whole thing took.

DRILL 2: BREACH TABLETOP

- [ ] Describe a realistic breach: a laptop stolen from a car, or a mis-sent spreadsheet.
- [ ] Talk through each step of your plan out loud.
- [ ] Decide whether it needs reporting to the authority and to individuals, and why.
- [ ] Fill in the breach log as if it were real.

DAY
27

Run the two drills

- [ ]

TODAY'S TASK Test the rights-request procedure and the breach plan using realistic scenarios, and note what went wrong.

WHY IT MATTERS Drills reveal missing contact details, unclear ownership and slow handovers while the stakes are still zero.

TIME NEEDED 45 minutes

CHECK What is the single change that would have made both drills faster?

OUTPUT Drill notes and fixes saved in 06 Security & Breaches.

Day 28: Week 4 review

Update the policies, procedures and registers with everything the drills taught you. Then re-check security: have all the fixes from Days 23 and 24 really been done, or are some still on a to-do list? Ask someone to find a gap in each document you wrote this week.

WEEK 4 COMPLETION CHECK

- [ ] A rights-request procedure and log are in place.
- [ ] Access is limited, reviewed and protected with multi-factor authentication.
- [ ] A written security baseline has been applied to devices, email and backups.
- [ ] A breach plan and breach log exist and the team knows who to tell.
- [ ] The whole team has been trained and attendance is recorded.
- [ ] Both drills have been run and their lessons applied.

DAY
28

Review Week 4 and apply what the drills taught you

TODAY'S TASK Fix every weakness found during the week and make sure each fix is recorded.

WHY IT MATTERS Improvement based on a real test is one of the strongest signs of a living compliance programme.

TIME NEEDED 45 minutes

CHECK What are the three things that most reduced our risk this week?

OUTPUT Updated documents and a dated Week 4 review note in 07 Reviews.

WEEK 5 · DAYS 29 AND 30

CHAPTER

06

Week 5: The Finish Line

Days 29 and 30. Prove what you built, measure your progress and plan the next 90 days.

IN THIS CHAPTER

- How to assemble your evidence folder into a single proof of compliance
- Your final Compliance Score and the progress since Day 1
- A 90-day plan and a yearly rhythm that keeps the work alive
- The mistakes that undo good programmes

You have written, mapped, tested and trained for four weeks. The final two days turn all of that into something you can show, and make sure it does not fade the moment the challenge ends. Compliance is not a finish line you cross once. It is a habit you keep.

Day 29: Assemble your evidence and retake the score

Open your **GDPR Evidence** folder and walk through the seven subfolders. Each should contain at least one dated document. Make a one-page index at the top that lists every document, its date and its owner. This index is what you would hand to a client, an insurer or a regulator if they asked, "Can you show me how you comply?"

Your evidence index

Folder	Core documents you should now have
01 Governance	Owner and scope note, principles check, role table, bases table, policies, training record, DPIA screening
02 Data Map	System register, data flows, vendor register, transfers, retention rules, ROPA
03 Notices & Consent	Privacy notice, cookie list and settings, marketing consent summary
04 Contracts	Signed data processing agreements and transfer clauses
05 Rights Requests	Procedure, request log, templates
06 Security & Breaches	Access review, security checklist, breach plan, breach log, drill notes
07 Reviews	Four weekly review notes, final scorecard, 90-day plan

Now retake the ten-question score from "Before Day 1". Be as honest as you were the first time. Then use the scorecard in the Bonus section to score each of the five areas.

FINAL COMPLIANCE SCORE: THE SAME TEN QUESTIONS

- [ ] Someone is named as responsible for data protection in my business.
- [ ] I can list the systems and tools that hold personal data.
- [ ] I know the lawful basis for each main use of personal data.
- [ ] My website has a privacy notice that matches what I really do.
- [ ] Cookies and trackers only run after a valid choice from the visitor.
- [ ] Every supplier that handles personal data has a signed data processing agreement.
- [ ] I know how long I keep each type of data and why.

- [ ] I have a written process for access, deletion and other requests.
- [ ] I have a written breach plan and know the 72-hour rule.
- [ ] My team has had basic privacy and security training.

DAY **29**

Build the evidence index and retake your score ☐

TODAY'S TASK Create the one-page evidence index, retake the starting score and write down the improvement.

WHY IT MATTERS Accountability (Art. 5(2)) means being able to demonstrate compliance. An index turns a folder of files into a clear story.

TIME NEEDED 60 minutes

CHECK How many points did we gain, and which area still scores lowest?

OUTPUT Evidence index and final score saved in 07 Reviews.

Day 30: Plan the next 90 days and set your rhythm

The last day looks forward. List the gaps that remain, rank them by risk and effort, and plan the first 90 days after the challenge. Then put the **recurring** tasks in the calendar so that compliance runs on routine, not on memory.

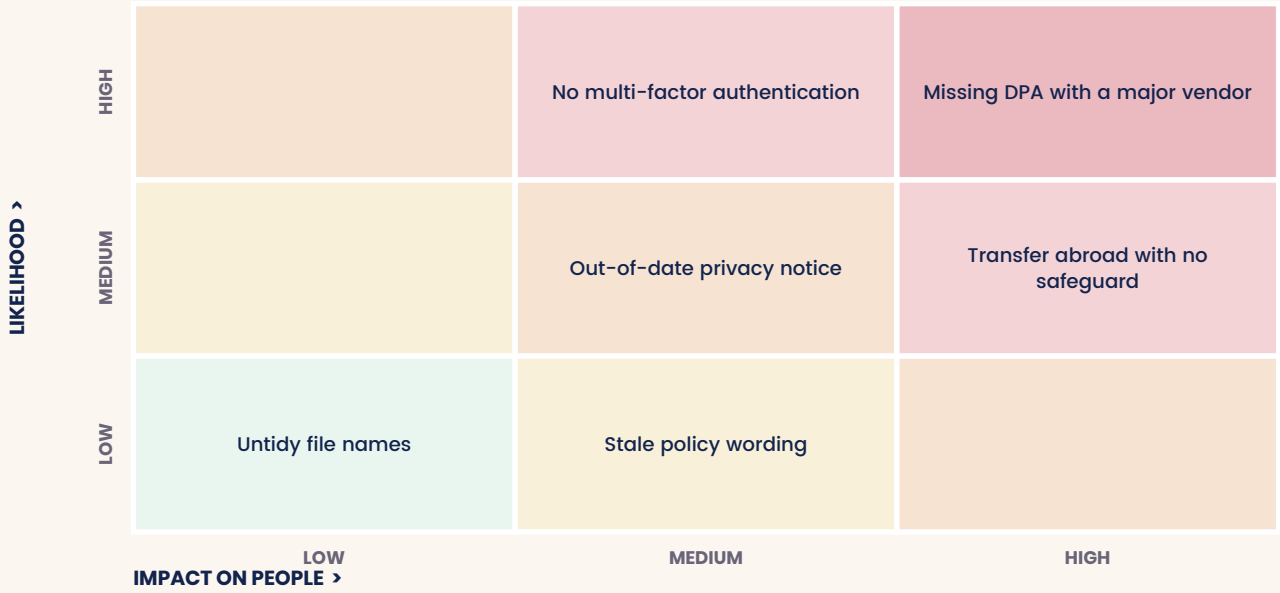


Figure 18 Rank your gaps: likelihood of harm against impact on people

Every month	**Check the breach log and the request log** Anything open? Anything late?
Every quarter	**Clean marketing lists and review access** Remove inactive contacts and leavers' accounts.
Every six months	**Test a backup restore and run one drill** A rights request or a breach scenario.
Every year	**Full review of the register, ROPA, notice, vendors and policies** Retrain staff and update the Evidence Folder.
Any time	**Before launching a new tool, product or campaign** Check data, basis, vendor, transfer and DPIA first.

Figure 19 A year of light-touch compliance

WORKSHEET

Your 90-day plan

Write the actions, owners and dates. Keep it short and realistic.

Days 1 to 30: the three most important fixes

Days 31 to 60: the next three

Days 61 to 90: the next three and the date of our first review

DAY
30

Create your 90-day plan and yearly calendar ☐

TODAY'S TASK Choose the nine highest-priority improvements, assign owners and dates, and add the recurring tasks to the calendar.

WHY IT MATTERS Without a plan and a rhythm, records go stale. A review date turns a one-off project into a habit.

TIME NEEDED 45 minutes

CHECK What is the first thing we will do on day 31?

OUTPUT 90-day plan and calendar entries saved in 07 Reviews.

Eight mistakes that undo a good programme

Documents nobody updates
A notice that is two years old no longer describes your business.

No owner
When the named owner leaves, privacy belongs to nobody again.

Ignoring changes
New tools, campaigns and suppliers all bring new data and new duties.

Treating security as one-off
Access drifts, patches slip and backups go untested.

Letting lists grow
Dead contacts add risk and drag down results.

Hiding mistakes
A hidden breach is much worse than a reported one.

Forgetting vendors
A new tool sends data abroad before anyone checks.

Skipping the review
One day a year is enough, as long as it actually happens.

Figure 20 What to avoid after the challenge ends

GOOD PRACTICE **GOOD PRACTICE: celebrate the finish**

You have done what many businesses never do. Share the result with the team, thank the people who helped and put the next review date in everybody's calendar. Cultures change when effort is noticed.

GDPR IN PLAIN ENGLISH **GDPR IN PLAIN ENGLISH: this is the start**

Regulations, case law and national guidance change, and so does your business. Check your supervisory authority's website and the European Data Protection Board's guidance at least once a year, and take professional advice for anything high-risk.

BONUS

Challenge Toolkit

Your 30-day tracker, ready-to-fill registers and the final scorecard. Fill them in on screen or print them.

IN THIS CHAPTER

- A 30-day progress tracker you can tick off
- A ROPA, vendor register and inventory to copy into
- A final scorecard and a one-page evidence index

WATCH OUT **How to use the toolkit**

Every table here has fillable fields in the PDF and ruled boxes in print. These are **educational templates, not legal advice**. Adapt them to your business and check the details against the rules in your country.

30-Day Progress Tracker

Tick each tile when you have finished the day and saved its output. Colours show the week: foundations, data map, documents, people and protection.

DAY 01 ☐	DAY 02 ☐	DAY 03 ☐	DAY 04 ☐	DAY 05 ☐	DAY 06 ☐
DAY 07 ☐	DAY 08 ☐	DAY 09 ☐	DAY 10 ☐	DAY 11 ☐	DAY 12 ☐
DAY 13 ☐	DAY 14 ☐	DAY 15 ☐	DAY 16 ☐	DAY 17 ☐	DAY 18 ☐
DAY 19 ☐	DAY 20 ☐	DAY 21 ☐	DAY 22 ☐	DAY 23 ☐	DAY 24 ☐
DAY 25 ☐	DAY 26 ☐	DAY 27 ☐	DAY 28 ☐	DAY 29 ☐	DAY 30 ☐

The 30 days at a glance

Week-by-week summary

Days	Theme	Main outputs
1 to 7	Foundations	Owner and scope, principles check, role table, quick inventory, lawful bases, high-risk list
8 to 14	Data mapping	System register, flows, vendor register, transfers, retention rules, ROPA
15 to 21	Documentation	Privacy notice, cookie fixes, marketing consent, DPAs, policies, DPIA screening
22 to 28	People and protection	Rights procedure, access review, security baseline, breach plan, training, drills
29 to 30	Finish line	Evidence index, final score, 90-day plan, yearly calendar

RECORD OF PROCESSING ACTIVITIES

Purpose	People and data	Lawful basis	Recipients	Transfers	Retention	Security
e.g. Order fulfilment	*Customers: name, address, order*	*Contract*	*Courier, payment provider*	*None*	*7 years (tax)*	*Access control, encryption*

VENDOR AND PROCESSOR REGISTER

Vendor	Service	Data received	Location	Transfer route	DPA signed	Review date
e.g. Email platform	*Newsletters*	*Names, emails*	*EU / USA*	*SCCs*	*2026-03-12*	*2027-03*

QUICK DATA INVENTORY

Group of people	Types of data	Where it lives	Rough amount	Special category?
e.g. Job applicants	*CVs, contact details*	*Email, HR tool*	*About 40*	*No*

Group of people	Types of data	Where it lives	Rough amount	Special category?

PURPOSES AND LAWFUL BASES

Purpose	Lawful basis	Why this basis	Balancing test needed?
e.g. Newsletter	*Consent*	*Optional marketing*	*No*

BREACH LOG

Date found	What happened	Data and people affected	Reported?	Action taken
e.g. 2026-05-10	*Email sent to wrong customer*	*One person, order details*	*No, logged*	*Recipient asked to delete*

RIGHTS REQUEST LOG

Date received	Type and requester	Deadline	Reply sent	Notes
e.g. 2026-04-02	*Deletion, customer*	2026-05-02	2026-04-09	*Invoices kept for tax*

Template 1: One-page breach response plan

[Business name] · Version [1.0] · Owner [Name and role] · Next review [DD Month YYYY]. Copy this into your own document and replace every [bracket].

1. What counts as a breach

Any incident that causes accidental or unlawful destruction, loss, alteration, unauthorised disclosure of, or access to personal data. Examples: a lost laptop or phone, an email sent to the wrong person, a hacked mailbox, ransomware, a shared link left open to anyone.

2. What every team member does

- Tell [privacy owner, phone and email] **immediately**, day or night. Do not wait to be sure, and do not try to fix it quietly.
- Write down what you know: what happened, when, what data, which systems.
- Do not delete evidence, and do not contact the people affected unless asked to.

3. What the privacy owner does

- Within 1 hour: contain the incident (change passwords, revoke access, recall or lock devices, disable links).
- Within 24 hours: assess what data, how many people, whether it was protected (for example encrypted) and how likely harm is.
- Record the incident in the breach log, whatever the outcome.
- Decide whether to notify the supervisory authority, [name and contact of your authority], without undue delay and where feasible within 72 hours of becoming aware, unless the breach is unlikely to result in a risk to people.
- If the breach is likely to result in a high risk, inform the affected people directly, in plain language, with advice on what to do.
- Inform affected clients, where you are their processor, without undue delay, so that they can meet their own deadlines.

4. After the incident

Within [14] days, hold a short review: what caused it, what worked, what to change. Update the plan, the training and the security measures accordingly, and record the date of the review.

Template 2: Rights request reply

Use the version that fits. Always send it from the address that received the request, and keep a copy in the request log.

Reply to an access request

Dear [Name], thank you for your request of [date]. We confirm that we process personal data about you. Attached is a copy of that data. In summary: we use it for [purposes], on the basis of [lawful basis]; it is shared with [recipients]; we keep it for [periods]; and the source of the data is [source]. You also have the right to ask us to correct or delete it, to restrict or object to its use, and to complain to [supervisory authority]. If you have any questions, please reply to this email. Kind regards, [Name, role]

Reply to a deletion request

Dear [Name], thank you for your request of [date]. We have deleted [list the data and systems] from our records. We have kept [list, for example invoices and payment records] for [period] because [legal reason, for example tax law requires it], and [for example a record of your unsubscribe, so that we do not contact you again]. We will delete these records at the end of that period. If you disagree, you may complain to [supervisory authority]. Kind regards, [Name, role]

FOUNDER TIP **FOUNDER TIP: always say what you kept and why**

A reply that says only "done" or only "we cannot" invites a complaint. Name the data, the reason and the end date.

Template 3: Freelancer and small-supplier data agreement

This short checklist covers the points of **Article 28(3)** for a small supplier who has no standard agreement of their own. Have a lawyer check the final wording for anything high-risk.

POINTS TO COVER IN A ONE-PAGE SUPPLIER AGREEMENT

- [ ] The parties, the service and the types of personal data and people involved.
- [ ] The supplier acts only on your written instructions, including for transfers outside the EEA.
- [ ] Everyone who handles the data is bound by confidentiality.
- [ ] The supplier applies appropriate security (for example access control, encryption, updates) and lists the main measures.
- [ ] The supplier uses no other helper or sub-contractor without your written approval.
- [ ] The supplier helps you answer rights requests and tells you quickly if they receive one.
- [ ] The supplier tells you without undue delay if there is a breach.
- [ ] At the end of the work, the supplier deletes or returns all data and confirms in writing.

- [ ] You can ask for information to show compliance.

Template 4: Privacy notice skeleton

Use these headings as the outline of your own notice, and fill each one from your ROPA. Write in short sentences and keep a version history.

- **Who we are.** Business name, address, contact email, and DPO details if applicable.
- **What we collect.** Grouped by situation: customers, website visitors, newsletter subscribers, job applicants.
- **Why we use it, and on what basis.** One row per purpose, with the lawful basis, and the legitimate interest where relevant.
- **Who we share it with.** Categories of recipients, for example payment provider, courier, accountant, email platform.
- **Transfers outside the EEA.** Where, and the safeguard used.
- **How long we keep it.** A period or clear criteria for each category.
- **Your rights.** Access, correction, deletion, restriction, objection, portability, and withdrawing consent, and how to use them.
- **Complaints.** Your right to complain to the supervisory authority, and its name.
- **Changes and date.** When the notice was last updated.

WATCH OUT **WATCH OUT: templates are a starting point**

A template cannot know what your business really does. Replace the generic parts with your own facts, delete what does not apply, and have anything high-risk checked by a qualified professional.

Final scorecard

Score each area from 0 (nothing in place) to 4 (written, tested and reviewed). Add the five scores for your total out of 20, and compare it with your "Before Day 1" score.

CATEGORY	YOUR SCORE	OUT OF
Foundations: owner, principles, roles, lawful bases		4
Data map: systems, flows, vendors, transfers, ROPA		4
Documents: notice, cookies, consent, contracts, policies		4
People and rights: requests, training, drills		4
Security and breaches: access, devices, plan, log		4
TOTAL SCORE		**20**

WORKSHEET

Evidence index

List each document, its date and its owner. This page is what you show a client, insurer or regulator.

Governance documents (dates and owners)

Data map documents (dates and owners)

Notices, contracts and policies (dates and owners)

Next review date and who will lead it

Plain-English Glossary

The terms you will meet on the way, in alphabetical order.

Accountability	The duty to comply with the GDPR and to be able to prove it (Art. 5(2)).
Consent	A freely given, specific, informed and unambiguous choice by the person, shown by a clear statement or action (Art. 4(11)).
Controller	The organisation that decides why and how personal data is processed.
Data subject	The person the personal data is about.
DPA	A data processing agreement between a controller and a processor (Art. 28). Not to be confused with a data protection authority.
DPIA	Data Protection Impact Assessment: a risk assessment for processing likely to be high risk (Art. 35).
DPO	Data Protection Officer: a role that is mandatory only in certain cases (Arts. 37 to 39).

EEA	The European Economic Area: the EU member states plus Iceland, Liechtenstein and Norway.
Legitimate interests	A lawful basis that needs a balancing test between your interest and the person's rights.
Personal data	Any information relating to an identified or identifiable person (Art. 4(1)).
Personal data breach	A security incident leading to destruction, loss, alteration, disclosure of or access to personal data (Art. 4(12)).
Processing	Anything done with personal data: collecting, storing, using, sharing, deleting.
Processor	An organisation that processes personal data on behalf of a controller.
ROPA	Record of Processing Activities (Art. 30).
SCCs	Standard Contractual Clauses: approved contract terms for transfers outside the EEA.
Special-category data	Sensitive data such as health, beliefs, biometrics and sexual orientation (Art. 9).
Supervisory authority	The national data protection regulator, such as the CNIL in France.

Official Sources & Further Reading

Where the legal claims in this book come from, and where to check what applies today.

Always prefer the primary sources below to summaries, including this one. Web addresses change: if a link has moved, search the official site for the title shown. Guidance is updated regularly, so check for the latest version.

Primary EU law (EUR-Lex)

- **General Data Protection Regulation (GDPR)**, Regulation (EU) 2016/679. Notably Art. 4 (definitions), Art. 5 (principles), Art. 6 (lawful bases), Art. 7 (consent), Art. 8 (children), Art. 9 (special categories), Arts. 12 to 22 (information and rights), Art. 28 (processors), Art. 30 (records), Art. 32 (security), Arts. 33 and 34 (breaches), Art. 35 (DPIA), Arts. 37 to 39 (DPO), Chapter V (Arts. 44 to 49, transfers) and Art. 83 (fines).
- **ePrivacy Directive**, Directive 2002/58/EC, Art. 5(3) (cookies and similar technologies) and Art. 13 (unsolicited communications), as implemented in national law.
- **Court of Justice of the EU, Case C-673/17 (Planet49)**, judgment of 1 October 2019, on pre-ticked boxes and cookie consent.
- **European Commission**, adequacy decisions and the EU-US Data Privacy Framework decision of 10 July 2023: commission.europa.eu

Regulators and guidance

- **European Data Protection Board (EDPB)**, guidelines on consent, DPIAs, personal data breach notification, controllers and processors, and transfers: edpb.europa.eu
- **Your national data protection authority**, for national rules, DPIA lists, breach-reporting forms and guidance. Find yours on the EDPB website.

WATCH OUT **What this book could not verify for you**

Retention periods, tax and employment rules, soft opt-in conditions for marketing, the age of digital consent and DPIA lists differ by country. The examples here are illustrative starting points. Reform proposals and court decisions may change parts of the picture after publication, so check the official sources above before you rely on any detail.

About the Author

Zirlandia Milkovic

Zirlandia Milkovic writes practical, plain-English guides on data protection, AI and building a business with confidence. She believes privacy is not a barrier to ambition but a foundation of trust, and that founders should not need a legal degree to understand the rules that apply to them.

She is the author of a series of business guides, including *GDPR Made Simple for Women Founders*, and her work focuses on turning complex European rules into simple steps, checklists and templates that busy founders can actually use. She is also behind **GDPRGard**, a growing collection of free GDPR tools, guides and articles for small businesses, available at gdprgard.eu.

Stay in touch

Visit **gdprgard.eu** for free tools, articles and updates, including notes on changes to the rules covered in this book. If this guide helped you, an honest review where you bought it helps other businesses find it.

AI & PRIVACY **Note to the reader**

This book is educational and not legal advice. Laws and guidance change, so check the sources in the previous section and consult a qualified professional about your own circumstances.



Thirty days.
One habit at a time.
Proof that you did the work.

ZIRLANDIA MILKOVIC